



VORONVIGIL

Sovereign AI OMS Supplier Compliance and Trust-Centric Third-Party Risk Management Platform

Solution Proposal

Version: 1.1

Date: 11th September 2026

VoronSigil Proposal

Contents

Executive Summary	4
1. Problem Statement	5
1.1 OMS supplier oversight is complex and high consequence	5
1.2 Existing assurance is commonly fragmented	5
1.3 Bursa OMS oversight requires supplier and service specificity	6
1.4 The Trust-Risk Gap	7
1.5 Sovereignty and Privacy Challenge	7
2. Proposed Solution: VoronVigil	8
2.1 Business outcomes	9
2.2 Regulatory and OMS alignment	10
2.3 OMS compliance pack	12
3. Sovereign AI and Data Sovereignty	13
3.1 VoronVigil Sovereign AI Zone	13
3.2 Appropriate AI uses	14
3.3 AI boundaries	15
3.4 Malaysia PDPA-by-design position	15
3.5 Data sovereignty commitments	16
4. VoronVigil Operating Model and Architecture	17
4.1 Supplier assurance lifecycle	17
4.2 Architecture layers	18
4.3 Critical design decisions	19
5. Evidence, Contract and Service Assurance	20
5.1 Evidence model	20
5.2 Control statuses	20
5.3 Event-driven reassessment	20
6. Cyber Trust Degradation Model (CTDM)	21
6.1 Purpose of CTDM	21
6.2 CTDM within VoronVigil	22
6.3 CTDM dimensions	23
6.4 CTDM scoring approach	25
6.5 OMS-specific interpretation	26
6.6 Illustrative OMS scenario	27
6.7 CTDM lifecycle use in VoronVigil	28
6.8 CTDM governance and limitations	29
7. Implementation Roadmap	30

VoronSigil Proposal

8. Success Criteria and Decision Request	32
8.1 Success criteria	32
8.2 Decision requested	33
Appendices.....	34
A. Assumptions	34
B. Demo Example	34

Executive Summary

This proposal recommends the implementation of VoronVigil, a Malaysia-hosted, sovereign-AI-enabled Third-Party Risk Management (TPRM) platform for the oversight of Order Management System (OMS) providers used by Bursa Malaysia Participating Organisations (POs).

VoronVigil is designed to establish a disciplined, evidence-led assurance model for OMS arrangements. It enables a PO to maintain a complete OMS supplier inventory, assess contractual obligations, monitor service delivery and resilience, manage remediation, quantify trust-degradation risk through CTDM, and generate an audit-ready response pack aligned to the supplied OMS Supplier Compliance Overview.

The platform is built around two strategic commitments:

1. Sovereign AI: private AI inference and retrieval operate within the VoronVigil Malaysia-hosted environment, governed by PO access controls, evidence boundaries, audit logs and human review.
2. Data sovereignty by design: supplier, PO and potentially personal data are hosted and processed in Malaysia by default, with strict controls over purpose, minimisation, access, security, retention, integrity and cross-border transfer.

AI is used to accelerate document extraction, contractual clause mapping, evidence analysis, assessment drafting and management reporting. It does not calculate authoritative compliance, residual-risk or CTDM scores, approve suppliers, accept risk, make legal determinations, or alter evidence. Those decisions remain with deterministic services and accountable PO personnel.

1. Problem Statement

1.1 OMS supplier oversight is complex and high consequence

OMS providers are not conventional technology suppliers. Depending on the arrangement, they may provide only infrastructure or fully manage the OMS environment; support market-facing order-management processes; serve retail clients, institutional clients, dealer representatives or market makers; process sensitive PO or client information; integrate with critical systems; and influence the availability and recoverability of important services.

A disruption, cyber incident, weak contractual obligation, untested recovery arrangement or unmanaged supplier performance issue can therefore create operational, regulatory, customer, reputational and trust-related consequences for the PO. The supplier's corporate assurance material alone is not sufficient: the PO must demonstrate assurance over the actual OMS service arrangement it consumes.

1.2 Existing assurance is commonly fragmented

In many organisations, the information required to oversee an OMS provider is dispersed across procurement repositories, shared drives, email, contract-management folders, operational dashboards, ticketing systems, vendor questionnaires, BCP/DR files and presentation material. This fragmentation creates recurring control weaknesses:

- Supplier information is maintained at a corporate level but is not linked to the specific OMS service, its users, service model, data access, criticality or contractual terms.
- Contracts and SLAs are stored as documents but clauses are not systematically mapped to applicable control obligations.
- Supplier performance and service reports are reviewed inconsistently, with limited evidence of management review or follow-up action.
- BCP/DR documents may exist but the PO cannot readily demonstrate that recovery capability, RTO commitments, data restoration and continuity plans have been tested and remain effective.
- Evidence is collected manually during audits or regulatory requests, resulting in late discovery of missing documents, expired attestations or unresolved gaps.

- Risk ratings are often opaque, inconsistent or disconnected from evidence, performance history and business dependency.
- AI may be considered for efficiency, but externally hosted AI raises legitimate questions around confidential contracts, supplier security evidence, data location, retention, model training and auditability.

1.3 Bursa OMS oversight requires supplier and service specificity

The supplied OMS Supplier Compliance Overview requires detailed evidence of supplier oversight across onboarding and due diligence, ongoing monitoring, incident management and escalation, TPRM, management of poor performance, supplier agreements, performance assessments, service reports, continuity and data recoverability. It also makes clear that where more than one OMS is used and arrangements differ, the PO should provide a separate response tailored to the relevant OMS rather than a generalised or consolidated response.

This requirement creates a material design implication:

$$\text{Required Assurance Unit} = PO \times OMS \text{ Provider} \times OMS / \text{Service Arrangement}$$

A platform designed only around a generic Supplier record cannot adequately support this requirement. The required unit is the PO's actual relationship with an identified OMS provider for a particular OMS service and operating model.

1.4 The Trust-Risk Gap

Traditional TPRM focuses appropriately on contracts, controls, certifications, vulnerabilities, performance and regulatory obligations. However, an OMS provider can present elevated relationship-level risk even where a basic compliance assessment appears satisfactory. Examples include a highly depended-upon provider with weak recovery capability, a provider vulnerable to impersonation, a critical service with high client impact, or a supplier with poor incident communication.

POs therefore require a complementary lens to answer:

“If this OMS provider is compromised, impersonated, publicly exposed or unable to recover effectively, how severely could trust in the PO–supplier relationship deteriorate?”

This is the purpose of the CTDM overlay in VoronVigil. It does not displace existing risk or compliance processes; it makes trust fragility explicit, measurable and governable.

1.5 Sovereignty and Privacy Challenge

OMS assurance may involve supplier contracts, security schedules, incident reports, service reports, business-continuity plans, personal information, PO operational information and potentially client-related data. Use of uncontrolled external AI services for such documents may create unacceptable uncertainty around data residency, disclosure, model retention, training use, privileged access and cross-border processing.

A secure platform for Bursa-related OMS assurance must therefore allow POs to gain the efficiency of AI without surrendering control of sensitive information or accountable decision-making.

2. Proposed Solution: VoronVigil

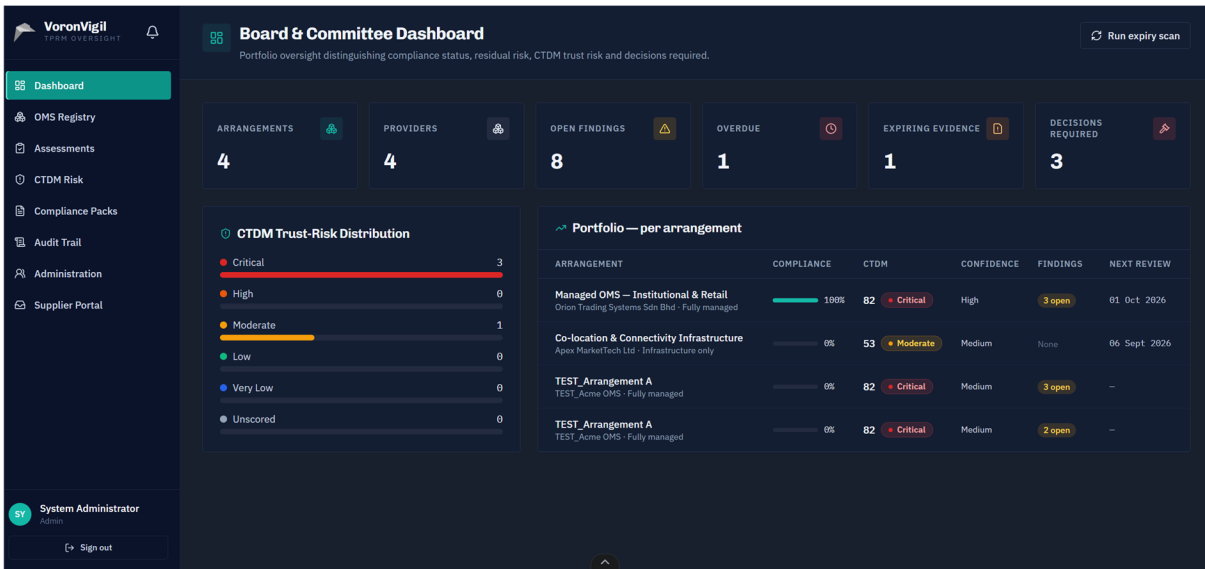


Figure 1: VoronVigil Dashboard

VoronVigil is an evidence-led TPRM and supplier compliance platform designed for OMS provider oversight. It provides a single governed environment to register each OMS arrangement, map agreement obligations, collect and assess evidence, monitor supplier performance and continuity, manage remediation, maintain audit trails, produce compliance packs and support executive decisions.

VoronVigil proposition: Every OMS arrangement should be demonstrably understood, contractually controlled, continuously evidenced and governed in proportion to its operational dependency, regulatory relevance, data sensitivity and trust impact.

2.1 Business outcomes

VoronVigil enables POs to:

- Maintain a complete and accountable inventory of OMS providers, OMS services, user groups, operating models, contractual dates and PO owners.
- Identify incomplete, ambiguous, outdated or untested contractual protections before they become operational, regulatory or audit issues.
- Monitor supplier performance, service reports, SLA/KPI/KRI data, incidents, escalation, continuity, DR testing and data recovery in one governed record.
- Generate OMS-specific compliance responses with supporting evidence, source locations, owner/reviewer details and approval status.
- Manage findings, poor-performance actions, contractual gaps and residual-risk acceptance through accountable workflows.
- Provide management, risk committees and Boards with a clear distinction between compliance, residual risk, CTDM trust risk, open actions and decisions required.
- Apply private, sovereign AI to improve assessment efficiency without exposing sensitive evidence to uncontrolled external AI services.

2.2 Regulatory and OMS alignment

Requirement	VoronVigil capability	Core evidence
ITSS 10.3.1 — supplier agreement documents relevant security obligations	Agreement register, contract lifecycle and control-to-clause matrix	Executed SLA/MSA, security schedule, amendments
ITSS 10.3.2(a) — legal, regulatory, data-protection and IP obligations	Contractual obligation assessment and legal review workflow	Relevant clauses, DPA, legal schedule
ITSS 10.3.2(b) — agreed controls for access, review, monitoring, reporting and audit	Responsibility/control matrix	SLA, RACI, access and security procedures
ITSS 10.3.2(c) — incident requirements and procedures	Incident notification and escalation assessment	IR clause, notification requirement, contacts
ITSS 10.3.2(d) — contractual right to audit	Audit-right and supplier information-access assessment	Agreement clause, audit protocol, exception approval

VoronSigil Proposal

ITSS 10.3.2(e) — escrow, where applicable	Escrow applicability assessment	Escrow agreement or approved N/A rationale
ITSS 10.3.2(f) — testing evidence	Secure delivery and testing assurance workflow	VA/PT, release or secure-development evidence
ITSS 10.3.2(g) — supplier compliance with PO security requirements	PO requirement acknowledgement	Security addendum, attestation and assessment
ITSS 10.4.1 — regular performance monitoring	SLA/KPI/KRI monitoring, assessment scheduling and poor- performance actions	Service reports, availability/outage data, review minutes
ITSS 10.4.2 — review service reports	Service-report register and sign-off workflow	Report copies, review/action records
ITSS 10.4.3 — continuity capability after major failure/disaster	BCP/DR, RTO/RPO and data- recovery assurance	DR tests, recovery outcomes, restoration evidence

2.3 OMS compliance pack

The VoronVigil OMS Compliance Pack is generated from approved system records rather than manually assembled in a spreadsheet. It supports the following structure:

OMS compliance overview section	VoronVigil output
Section A — General Information	OMS/provider inventory, user groups, SLA signed/effective date, duration and operating model
Section A — Oversight	Evidence-based narrative for onboarding, monitoring, incident escalation, TPRM and poor performance
Section B — Supplier Agreement / Contract Management	Executed agreement, clause mapping, gap register, SLA review and data-recovery evidence
Section C — Service Delivery / Performance Monitoring	Assessment cadence, performance, supplier capability, cyber hygiene, resilience and governance evidence
Section D — Service Reports	OMS-specific report register, frequency, scope, latest report, review outcomes and actions

A pack cannot be marked submission-ready if a mandatory response, supporting-document reference, source location, reviewer approval or approved Not Applicable rationale is missing.

3. Sovereign AI and Data Sovereignty

3.1 VoronVigil Sovereign AI Zone

VoronVigil incorporates private AI as a dedicated, controlled platform capability. The private AI environment is located inside the VoronVigil Sovereign AI Zone, hosted in Malaysia and accessible only through a policy-enforcing internal AI gateway.

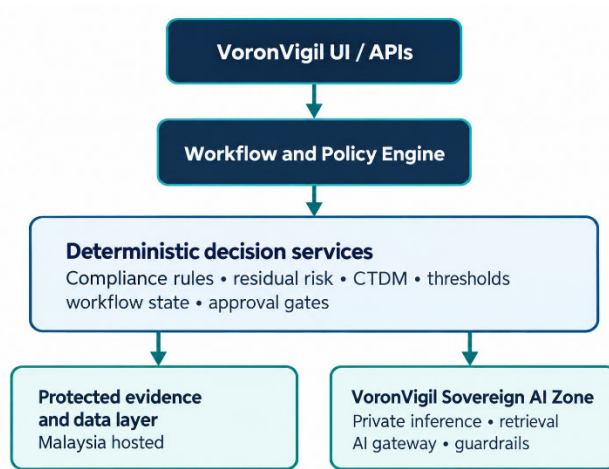


Figure 2: VoronSigil Sovereign AI Zone Architecture

The AI gateway enforces user access rights, supplier/OMS context, data classification, data minimisation, redaction, prompt policy and output schema. It records each execution with the model version, prompt version, evidence IDs, timestamp, output, confidence, reviewer outcome and override rationale.

3.2 Appropriate AI uses

VoronVigil workflow	Sovereign AI contribution	Human / deterministic authority
Supplier and OMS intake	Extract service model, data type, access, dependency, RTO/RPO and missing information	PO owner validates facts; tiering engine assigns tier
Agreement/SLA assessment	Identify clauses and map likely coverage against ITSS/OMS requirements	Legal/compliance confirms adequacy and exception
Evidence review	Extract relevant statements from SOC reports, certifications, security assessments, DR evidence and service reports	TPRM assessor approves evidence sufficiency and control status
Assessment drafting	Propose structured rationale, evidence request and finding	Rules engine calculates scores; assessor approves result
Service-report analysis	Summarise trends, breaches, recurring issues and overdue actions	Service manager validates performance conclusion
Compliance pack drafting	Draft questionnaire narrative using approved evidence only	PO owner/compliance reviewer approves final text
CTDM factor support	Identify evidence and explain trust drivers/change	CTDM engine calculates the authoritative result
Management reporting	Translate approved technical findings into decision-ready content	Management validates reporting and decisions

3.3 AI boundaries

Sovereign AI may extract, classify, summarise, correlate and recommend. It must not autonomously calculate authoritative compliance, residual-risk or CTDM scores; approve/reject/restrict a supplier; accept residual risk; approve a contract exception; determine legal adequacy; change policy/workflow/control definitions; alter or delete approved evidence; or treat unverified public information as a confirmed supplier conclusion.

Every AI result is a Draft AI Analysis until approved by the accountable VoronVigil reviewer.

3.4 Malaysia PDPA-by-design position

VoronVigil is designed to support the PO's privacy and data-protection governance. Malaysia's PDPA regulates processing of personal data in commercial transactions, and official guidance sets out the General, Notice and Choice, Disclosure, Security, Retention, Data Integrity and Access principles.

Malaysia hosting and private AI deployment provide stronger control over data residency and processing, but do not alone constitute PDPA compliance. The PO remains responsible for determining the lawful purpose and applicable privacy governance for its processing activities.

Privacy and data sovereignty objective	VoronVigil response
Purpose limitation	Restrict collection and AI processing to defined OMS assurance, risk, contractual and regulatory purposes
Data minimisation	Retrieve and submit only task-relevant document excerpts and approved structured context to the private AI layer
Disclosure control	Enforce PO, supplier, role and OMS-service boundaries; deny unauthorised data sharing by default
Security	Malaysia-hosted private inference; encryption; MFA/SSO; least privilege; segmentation; managed access and audit logging

Retention	Apply configured retention, legal hold, review and defensible disposal by evidence/data type
Data integrity	Preserve original documents, hashes, source/location, review decision, version history and correction workflow
Access	Support controlled information access/correction workflows and complete access logging
Cross-border governance	Require documented assessment and approval for any offshore processing, storage, support or integration exception

3.5 Data sovereignty commitments

- Production data, original evidence, retrieval indexes, private AI inference, audit records, backups and recovery capability are located in Malaysia by default.
- PO and supplier data are segregated by tenant and access policy; retrieval is scoped to the active supplier/OMS service instance and user entitlement.
- Data are not used for public or shared model training by default.
- External AI/API use for restricted or confidential evidence is blocked unless specifically approved through documented data-transfer and supplier-risk governance.
- Egress is deny-by-default, purpose-scoped, monitored and auditable.
- Encryption, key management, privileged access, backup restoration and disaster recovery are governed under the PO's approved security model.

4. VoronVigil Operating Model and Architecture

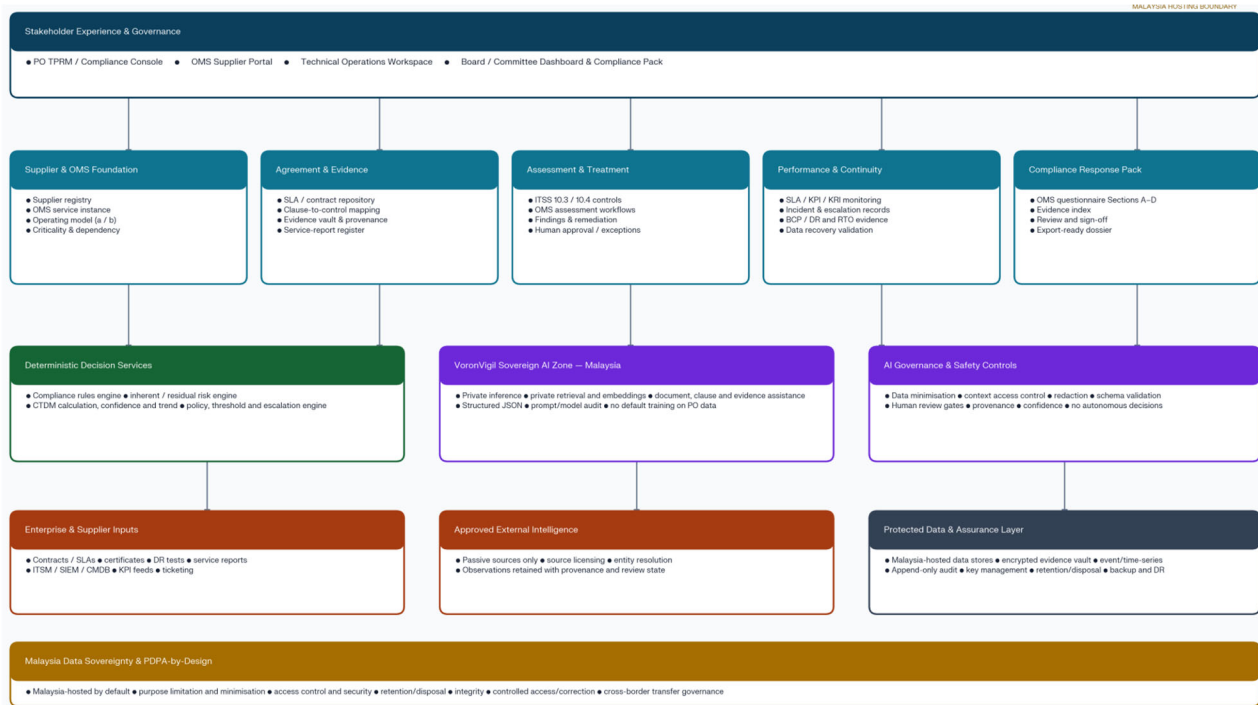


Figure 3: VoronSigil High Level Architecture

4.1 Supplier assurance lifecycle

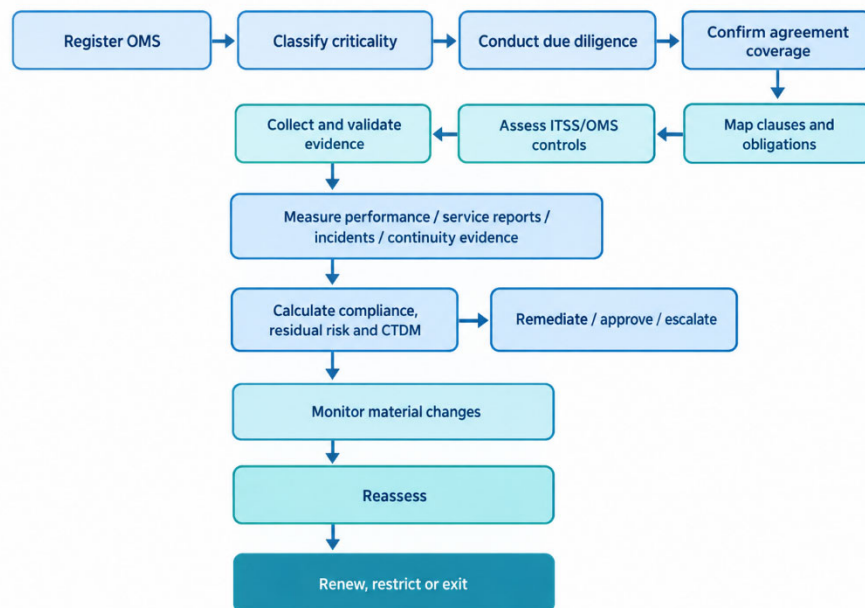


Figure 4: VoronSigil Operating Model

4.2 Architecture layers

Layer	VoronVigil components	Purpose
Stakeholder experience	PO TPRM/compliance console, supplier portal, operations workspace, Board/committee dashboard, compliance pack	Role-appropriate workflows and reports built on one record of truth
OMS compliance core	Supplier/OMS registry, agreement repository, control/assessment service, evidence vault, performance/continuity service, remediation workflow	Owens the regulated assurance lifecycle and evidence relationship
Deterministic decision services	Compliance rules, inherent/residual risk, CTDM, policy/threshold/escalation engine	Performs repeatable calculation, policy enforcement and workflow gating
VoronVigil Sovereign AI Zone	Private inference, private retrieval/embedding, evidence extraction, clause mapping support, structured assessment and report drafting	Accelerates controlled analysis in the Malaysia data boundary
Enterprise and supplier inputs	Contracts, SLAs, certificates, DR tests, reports, ITSM, SIEM, CMDB, KPI feeds and ticketing	Supplies internal and supplier-provided assurance evidence
Approved external intelligence	Permitted passive sources, source licensing, entity resolution and human review	Adds contextual signals without uncontrolled active testing
Protected assurance layer	Malaysia-hosted relational data, encrypted evidence store, event/time-series store and append-only audit	Protects data sovereignty, traceability, reporting and historical analysis

4.3 Critical design decisions

- OMS service instance is the core record.

VoronVigil stores independent service scope, operating model, PO owner, user groups, data/system access, agreement, RTO/RPO, assessment, service-report register and risk history for every OMS arrangement.

- Compliance pack is an output from live evidence.

The platform generates OMS response content from verified records and blocks submission-ready status where evidence, reviewer approval or required context is missing.

- Three outcomes remain separate.

Compliance status assesses whether an obligation is evidenced; residual risk assesses PO risk remaining after treatment; CTDM assesses trust degradation potential. They may be reported together but must not be hidden inside a single opaque score.

- AI assists, deterministic services decide.

Private AI supports evidence interpretation. Deterministic, versioned engines calculate scores and enforce thresholds. Accountable PO stakeholders make consequential decisions.

5. Evidence, Contract and Service Assurance

5.1 Evidence model

For every material conclusion, VoronVigil retains the supplier/OMS service instance, original document and hash, document version, source/received date, exact page/section, mapped control, evidence quality/freshness, reviewer, AI assistance metadata where used, finding/action and closure validation.

5.2 Control statuses

- Pass: adequate evidence supports the obligation and the reviewer approves the conclusion.
- Partial: evidence exists but is incomplete in scope or requires tracked improvement.
- Fail: evidence demonstrates absence or non-fulfilment.
- Insufficient Evidence: no reliable conclusion can be reached.
- Not Applicable: documented rationale, accountable owner, approval and future review date exist.
- Requires Review: specialist legal, technical, operational or compliance input is required.

5.3 Event-driven reassessment

VoronVigil opens a reassessment and applies policy-driven escalation when a material event occurs, including a major outage, repeated SLA breach, failed DR test, RTO breach, delayed incident notification, certificate/evidence expiry, significant contract amendment, unresolved audit right, or material change in OMS scope, data access, criticality or operating model.

6. Cyber Trust Degradation Model (CTDM)

6.1 Purpose of CTDM

The Cyber Trust Degradation Model (CTDM)© is a trust-centric risk quantification overlay for Third-Party Risk Management. It complements, but does not replace, conventional supplier due diligence, contractual assurance, compliance assessment, cyber-risk assessment, or residual-risk methodology.

Traditional TPRM focuses on important questions such as whether a supplier has appropriate security controls, maintains certifications, meets contractual obligations, and performs against agreed service levels. CTDM adds a different management question:

“If an OMS provider is compromised, impersonated, publicly exposed, or suffers a material service failure, how severely could trust in the PO–supplier relationship deteriorate?”

For a Bursa Malaysia Participating Organisation, this is particularly relevant because an OMS provider may support market-facing functions, process sensitive information, integrate with critical environments, serve dealer representatives or clients, and affect operational continuity. A supplier may appear broadly compliant but still create significant trust degradation risk if the PO is highly dependent on it, if the supplier is difficult to replace, if recovery capability is weak, or if an incident is likely to affect clients, operations, reputation, or regulatory confidence. CTDM makes this relationship-level exposure visible and actionable.

6.2 CTDM within VoronVigil

Within VoronVigil, CTDM is implemented as a separate, deterministic decision-support service. It must not be treated as a compliance score or an automated supplier-approval mechanism.

VoronVigil decision lens	Primary question	Management use
Bursa / OMS compliance	Are ITSS 10.3 and 10.4 obligations and OMS oversight requirements sufficiently evidenced?	Identifies contractual, service-delivery, reporting, and continuity gaps
Residual supplier risk	What risk remains after considering inherent exposure, controls, performance, incidents, and treatment?	Supports risk treatment, acceptance, escalation, and renewal decisions
CTDM trust degradation risk	How fragile is the PO's trust relationship with the OMS provider under cyber stress?	Identifies suppliers that require enhanced safeguards, executive attention, or continuous monitoring

This separation is intentional. A supplier can have a satisfactory compliance position while carrying elevated CTDM risk because the PO has a high operational dependency on the supplier or limited confidence in its ability to restore service and stakeholder trust after a material event. Conversely, a lower-criticality supplier may have control weaknesses but create less significant trust degradation exposure for the PO.

6.3 CTDM dimensions

CTDM evaluates five dimensions, each assessed using a 1–5 ordinal scale. A score of 1 represents very low exposure or capability, while a score of 5 represents very high exposure or capability. For Trust Recovery Capability, a higher score is positive because it represents stronger demonstrated recovery capability.

Dimension	Meaning	OMS provider context	Typical VoronVigil evidence
Trust Exposure (TE)	The extent to which the supplier's trusted identity, communications, brand, contacts, or operational presence is visible and potentially abusable	An OMS provider with public-facing support channels, visible executive profiles, predictable corporate email formats, and accessible employee information may present a larger impersonation or trust-abuse surface	Public-facing service and support profile, approved passive intelligence, public metadata, supplier identity records
Trust Exploitability (TX)	The ease with which adversaries may weaponise the supplier's trust identity through spoofing, impersonation, social engineering, or technical weaknesses	Weak email-authentication posture, lookalike domains, exposed support/procurement contacts, or prior impersonation incidents may increase the ability to misuse the supplier's identity	Validated DNS/email posture, entity-validated lookalike observations, incident history, material control gaps
Trust Dependency (TD)	The degree to which the PO relies on the supplier for critical operations, sensitive data processing, integration, or customer-facing service delivery	A fully managed OMS supporting dealer or client activity, connected to critical PO systems, or without a tested alternative provider will typically have elevated dependency	OMS criticality, user groups, service model, data classification, system integrations, concentration, exit and substitutability assessment

VoronSigil Proposal

Impact Amplifier (IA)	The extent to which a supplier failure would intensify regulatory, operational, financial, client, reputational, or market impact	A major OMS disruption may affect client confidence, trading-related operations, regulatory obligations, contractual commitments, and the PO's reputation	Business-impact analysis, regulatory mapping, client/service reach, financial/operational impact, concentration and service dependency
Trust Recovery Capability (TRC)	The supplier's demonstrated capability to respond, communicate, recover operations, restore data, and rebuild confidence after an event	A supplier with tested BCP/DR plans, proven RTO achievement, timely incident notification, recovery evidence, and clear stakeholder communication has stronger recovery capability	Incident response plan, notification procedure, BCP/DR plan, RTO/RPO, DR test result, data restoration evidence, SLA performance and post-incident reports

The highest direct alignment between CTDM and Bursa supplier management requirements is Trust Recovery Capability. ITSS 10.4.3 requires POs to ensure suppliers maintain sufficient service capability and workable continuity plans to maintain agreed service-continuity levels after major failure or disaster. The OMS overview also asks POs to explain how data residing with the OMS provider can be recovered in a timely manner. VoronVigil therefore evaluates demonstrated recovery capability, not merely the presence of an untested BCP/DR document.

6.4 CTDM scoring approach

CTDM uses the following practical weighted model:

$$TRG = 6 - TRC$$

$$CTDM_{100} = [(TE \times 0.20) + (TX \times 0.25) + (TD \times 0.25) + (IA \times 0.20) + (TRG \times 0.10)] \times 20$$

The Trust Recovery Gap converts positive recovery capability into a risk-increasing measure. A supplier with strong recovery capability of TRC = 5 has TRG = 1; a supplier with poor recovery capability of TRC = 1 has TRG = 5. This ensures that a supplier's inability to restore services and confidence following an event increases the trust degradation score.

CTDM score	Trust degradation band	Minimum management response
0–20	Very Low	Standard monitoring
21–40	Low	Periodic reassessment
41–60	Moderate	Enhanced due diligence and targeted safeguards
61–80	High	Stronger contractual safeguards, enhanced monitoring, remediation and management oversight
81–100	Critical	Executive review, formal remediation plan, risk-treatment decision and potential relationship restriction

6.5 OMS-specific interpretation

For VoronVigil, CTDM should be calculated at the OMS service-instance level, not only at the supplier legal-entity level:

$$CTDM\ Assessment\ Unit = PO \times OMS\ Provider \times OMS / Service\ Arrangement$$

This distinction is important because a single provider may offer multiple services with materially different criticality, operating responsibility, client reach, integration depth, recovery requirements, and contractual commitments.

For example, an OMS provider that only supplies server infrastructure may have lower operational responsibility than a provider that fully manages OMS configuration, maintenance, operations, security monitoring, incident response, and service continuity. However, the infrastructure-only arrangement could still produce high CTDM exposure if the PO has substantial operational dependency, no viable alternate environment, weak recovery evidence, and significant potential client impact.

6.6 Illustrative OMS scenario

Consider a fully managed OMS provider that supports a PO's dealer representatives and institutional clients.

CTDM dimension	Illustrative score	Rationale
Trust Exposure (TE)	3	The provider has a recognisable market presence, customer-support channels and publicly visible personnel
Trust Exploitability (TX)	4	Passive assessment identifies insufficient email-domain protections and a potential brand-impersonation risk requiring validation
Trust Dependency (TD)	5	The OMS is operationally critical, supports core order-management activities, and has limited short-term substitutability
Impact Amplifier (IA)	5	An extended service outage or compromise could affect operations, clients, regulatory confidence and reputation
Trust Recovery Capability (TRC)	2	BCP/DR documentation exists, but recent evidence does not demonstrate recovery within the PO-required RTO or timely data restoration

The Trust Recovery Gap is $TRG = 6 - 2 = 4$. The resulting CTDM score is 85/100, which is classified as Critical Trust Degradation Risk.

This score does not mean the OMS provider is technically compromised or contractually non-compliant. It means that the PO's reliance on the provider, combined with high potential impact and weak demonstrated recovery capability, creates a material risk that a cyber incident or major outage could significantly degrade trust in the PO-supplier relationship.

Appropriate VoronVigil actions could include:

- Require a validated remediation plan for BCP/DR and data-recovery capability.
- Require a joint incident-response and DR exercise against the agreed RTO/RPO.
- Strengthen SLA and contract provisions for incident notification, recovery, escalation, service reporting, audit rights, and service credits or other remedies where appropriate.

VoronSigil Proposal

- Review OMS concentration risk, exit strategy, and alternative processing arrangements.
- Increase service-performance monitoring and management reporting frequency.
- Escalate the result to the accountable risk owner and, where thresholds are met, the relevant management committee or Board.

6.7 CTDM lifecycle use in VoronVigil

CTDM should be embedded across the supplier's lifecycle rather than calculated only during onboarding.

Lifecycle stage	CTDM use within VoronVigil
Onboarding	Identifies whether an OMS provider requires enhanced due diligence, stronger contract terms, additional recovery evidence, or executive approval before engagement
Contract/SLA review	Identifies whether incident notification, audit rights, data recovery, continuity, secure delivery, monitoring, reporting and exit clauses reduce trust degradation exposure
Periodic assessment	Compares current trust posture against historical results and identifies deterioration, improvement, or persistent weaknesses
Ongoing monitoring	Detects material SLA breaches, recurring outages, evidence expiry, DR-test failures, control gaps, supplier changes, or validated external observations
Incident response	Supports assessment of the relationship-level impact of an incident, including whether recovery, disclosure, communication and remediation are restoring trust
Contract renewal	Provides a longitudinal view of whether the supplier's trust posture has improved, remained stable, or deteriorated over the contractual period
Exit and transition	Supports assessment of concentration, substitutability, data portability, transition readiness and residual trust/recovery exposure

6.8 CTDM governance and limitations

CTDM must be deployed as a controlled decision-support model. It is not an actuarial financial-loss model, a legal-compliance opinion, or a replacement for the PO's risk-management framework.

VoronVigil should apply the following governance controls:

- The authoritative CTDM score is calculated only by the deterministic CTDM engine.
- Private AI may extract evidence, recommend factor values and draft rationale, but must not calculate or override the authoritative score.
- Each factor score must retain evidence references, assessment date, confidence, reviewer, methodology version and approval status.
- CTDM confidence must be displayed separately from CTDM score. Low-confidence passive intelligence or incomplete evidence must not be presented as equally reliable as validated contractual, operational or supplier evidence.
- The initial CTDM factor definitions, weights and thresholds should be approved by the PO and reviewed periodically. They should be calibrated based on pilot experience, risk appetite, OMS criticality and management feedback.
- Any CTDM-driven action such as supplier restriction, contractual exception, risk acceptance, or escalation—must remain subject to accountable human approval.
- Trust recovery must be evidence-based. The score should not materially be reduced simply because time has passed; it should reduce only when the supplier demonstrates effective remediation, recovery capability, sustained performance and restored assurance.

CTDM should therefore be positioned in the proposal as a transparent trust-risk overlay that strengthens, rather than replaces, Bursa-aligned supplier agreement and service-delivery oversight.

7. Implementation Roadmap

Phase	Scope	Outcome
Phase 0 — Mobilise and design	OMS inventory, data classification, Malaysia sovereignty architecture, risk appetite, evidence landscape, contracts, controls and integration design	Approved target operating model, data map, security architecture and pilot scope
Phase 1 — Compliance foundation	Supplier/OMS registry, ITSS 10.3/10.4 controls, Malaysia-hosted evidence vault, assessment workflow, agreement register, audit trail and compliance pack	End-to-end evidence-backed OMS assessment and response pack
Phase 2 — Sovereign AI copilot	Private AI gateway, retrieval, document/contract/evidence assistance, structured outputs, review workflow and AI audit	Measurable analysis efficiency without loss of PO control or accountability
Phase 3 — Service and contract assurance	Clause review, SLA/service-report ingestion, KPI monitoring, incidents, BCP/DR evidence, remediation and committee reporting	Proactive visibility of agreement, performance and resilience gaps
Phase 4 — CTDM overlay	CTDM rubric, deterministic service, confidence/trend, event triggers and executive reporting	Reproducible trust-degradation analysis and governed management actions
Phase 5 — Continuous assurance	Approved integrations, passive intelligence, event-driven reassessment and multi-OMS rollout	Sustainable assurance across the critical supplier portfolio

Pilot recommendation

VoronSigil Proposal

Pilot VoronVigil using two distinct OMS arrangements: one provider supplying infrastructure only and one provider fully managing the OMS. This tests the ability to tailor responsibility mapping, contract assessment, evidence requests, monitoring, continuity requirements and CTDM dependency scoring to the actual operating model.

8. Success Criteria and Decision Request

8.1 Success criteria

- Every in-scope OMS service has a named owner, provider, operating model, criticality, agreement status and next review date.
- Each OMS compliance response is service-specific and contains supporting evidence or an approved Not Applicable rationale.
- ITSS 10.3/10.4 conclusions are independently reproducible from retained source evidence.
- Contract gaps, poor performance, continuity weaknesses and stale evidence are assigned, escalated and tracked to validated closure.
- Private AI outputs are evidence-bound, schema-valid, auditable and reviewed by authorised users.
- Restricted information is not sent to unapproved external AI services; Malaysia data-residency and egress controls are demonstrably effective.
- Board/delegated-committee reporting distinguishes compliance, residual risk, CTDM trust risk, confidence, actions and decisions required.
- CTDM results are deterministically calculated from reviewer-validated evidence.

8.2 Decision requested

Approval is requested to commence VoronVigil Phase 0–1, comprising:

1. OMS service-instance inventory, ownership and criticality assessment.
2. ITSS 10.3/10.4 control library and OMS overview mapping.
3. Malaysia-hosted evidence and provenance repository with secure supplier evidence workflow.
4. Agreement/SLA register and clause-to-obligation assessment capability.
5. OMS-specific assessment, remediation, approval and immutable audit trail.
6. VoronVigil OMS Compliance Pack for management and regulatory-response readiness.

Approval is also requested to design the sovereign-AI architecture during Phase 0 and to implement the private AI copilot in Phase 2, subject to PO security architecture, data classification, privacy governance, model assurance, operational-risk and cross-border transfer controls.

Appendices

A. Assumptions

- The PO will provide the current authoritative GTRM text and internal legal/compliance interpretation before final production control wording is approved.
- Malaysia hosting and data-residency design support sovereignty objectives but do not independently establish PDPA compliance; the PO retains responsibility for lawful processing and applicable governance.
- PO policy will define assessment cadence, materiality, risk appetite, delegated approval, evidence retention, external-source approval and cross-border exceptions.
- Legal/compliance personnel approve contract adequacy and exceptions; VoronVigil retains their decisions and supporting evidence.
- Sovereign AI remains private, evidence-bound and reviewable; it assists analysis without displacing human accountability.

B. Demo Example

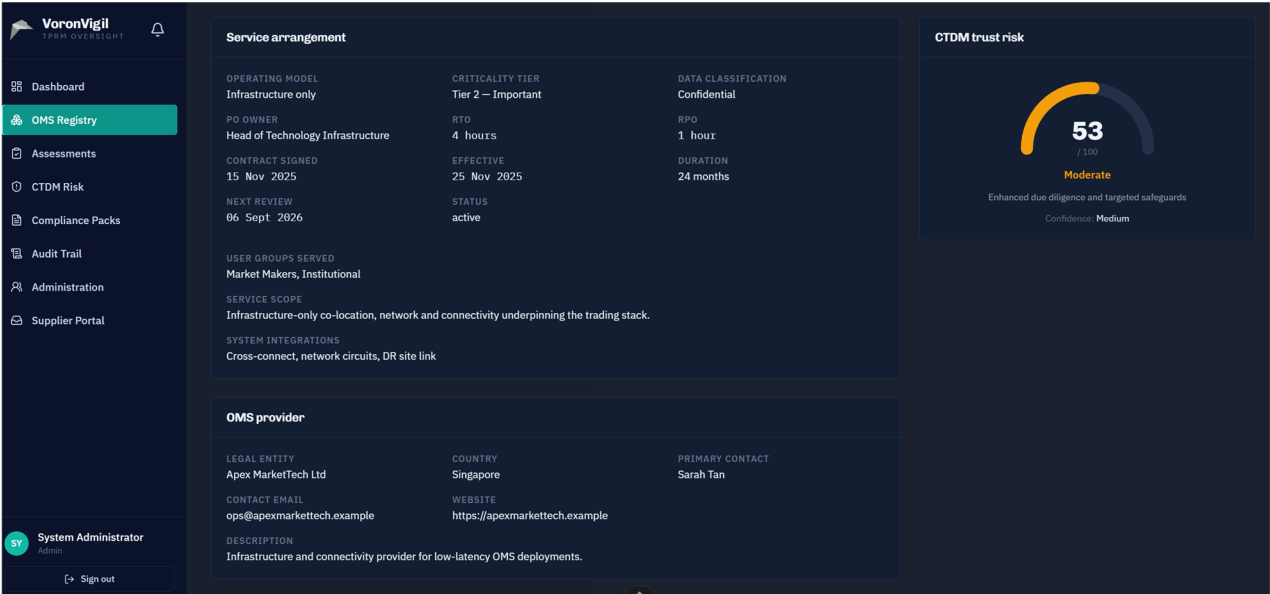


Figure 5: OMS Registry

VoronSigil Proposal

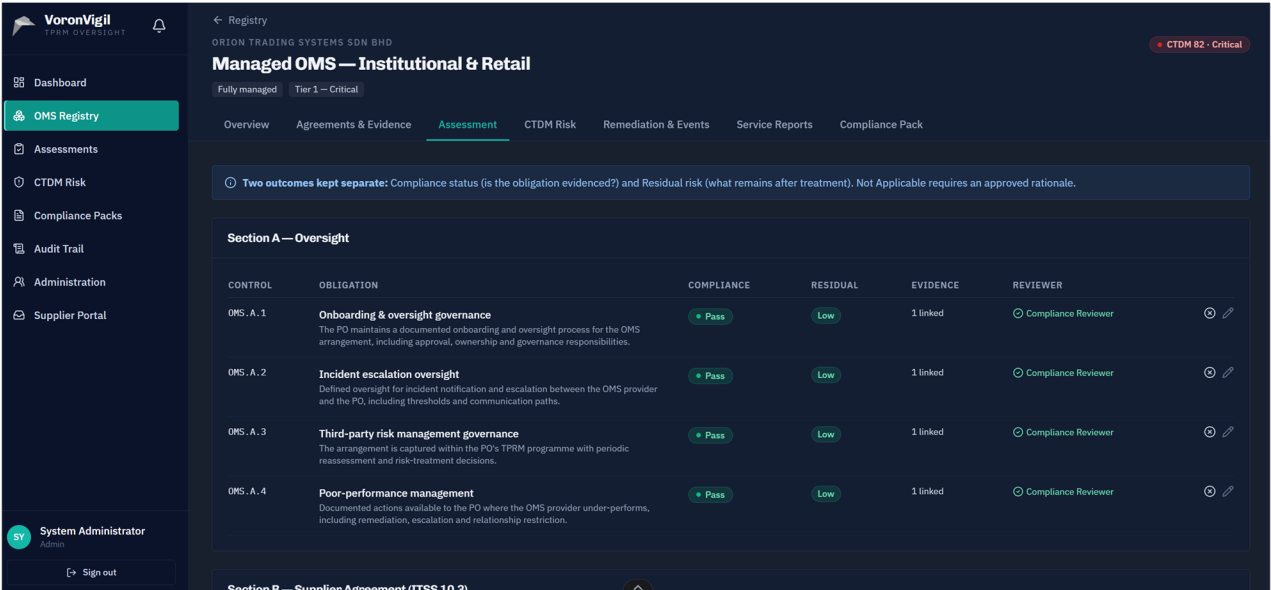


Figure 6: Third Party Risk Assessment

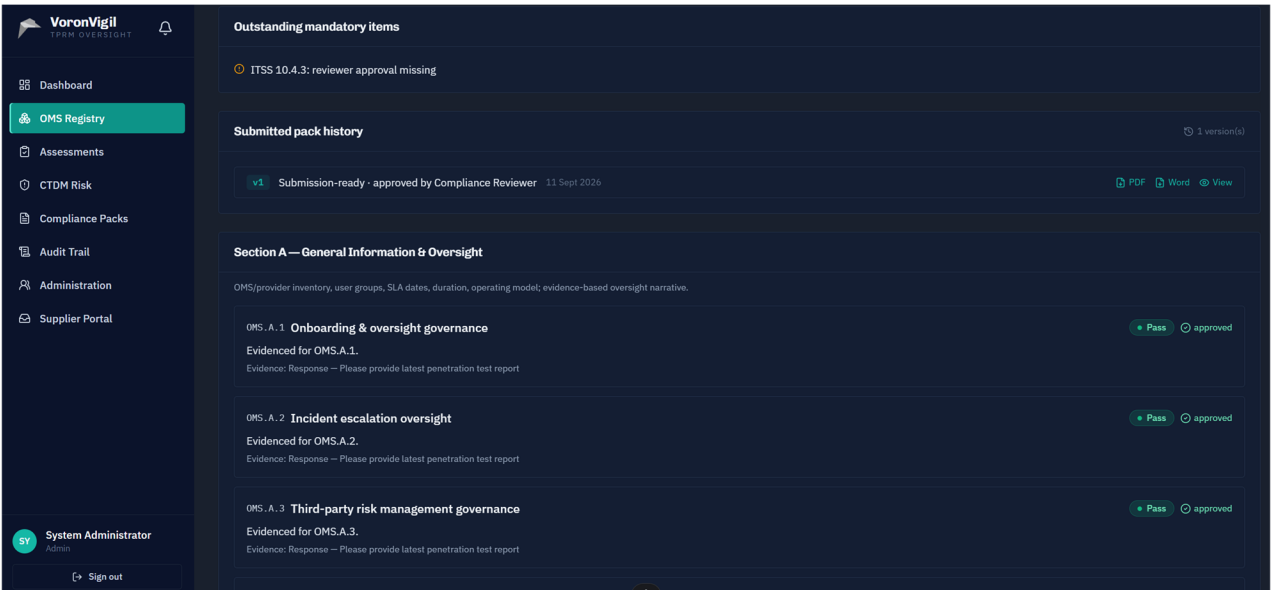


Figure 7: Compliance Pack Based on ITSS

VoronSigil Proposal

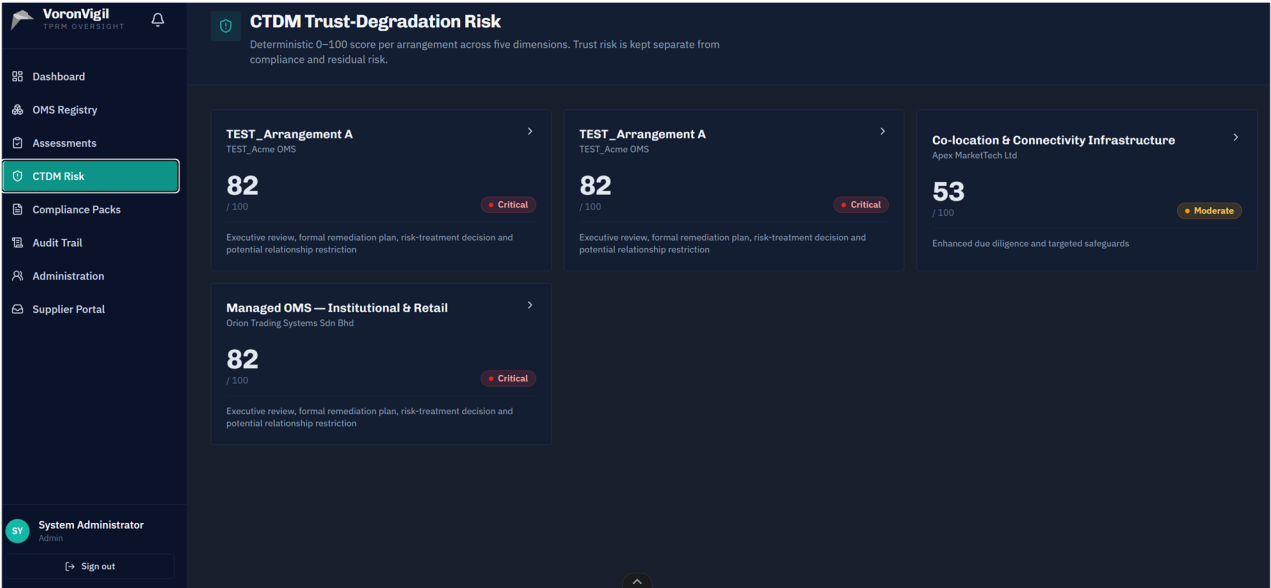


Figure 8: PO Scoring Based on CTDm Risk Modeling